VULNERABILITY ASSESSMENT REPORT

Target Website:
demo.testfire.net

Prepared By:
Vaishnavi Vijay Naik

Internship:
Cyber Security – Future Interns

EXECUTIVE SUMMARY

This report focuses on presenting the results of a vulnerability assessment conducted on a publicly accessible web application.

In today's digital environment, web application security plays a critical role in protecting user data, maintaining customer trust, and ensuring business continuity.

The objective of this assessment was to identify common security weaknesses using passive and non-intrusive techniques. No exploitation or active attacks were performed during the assessment.

Several security issues were identified during the assessment, including lack of HTTPS encryption, missing security headers, insecure cookie configurations, and absence of anti-CSRF protections.

While no critical vulnerabilities were exploited, these issues increase the overall risk and may expose the application to potential cyber threats.

This report provides clear findings and practical recommendations to improve the security posture of the application.

This assessment was conducted as part of my cybersecurity internship training.

OBJECTIVE

The objective of this assessment is to evaluate the security posture of a publicly accessible web application.

The assessment focuses on identifying common vulnerabilities, misconfigurations, and security gaps that could impact user data, system integrity, and business operations.

The goal is to provide clear, business-friendly insights along with actionable recommendations to improve overall security.

SCOPE

The assessment was limited to publicly accessible components of the web application.

No login bypass, brute force attacks, or exploitation techniques were performed.

All testing was conducted using passive analysis methods in accordance with ethical guidelines.

The assessment simulates a real-world security audit without causing any disruption to the system.

METHODOLOGY

The assessment was conducted using a structured and ethical approach focused on passive security analysis.

The following activities were performed:

- Inspection of HTTP response headers using browser developer tools

- Analysis of cookies and session configurations

- Passive vulnerability scanning using OWASP ZAP

- Network exposure analysis using Nmap

The methodology follows industry best practices inspired by OWASP guidelines.

No active exploitation or intrusive testing was performed.

TOOLS USED

The following tools were used during the assessment:

1. Chrome Developer Tools

Used to inspect HTTP headers, cookies, and client-side configurations.

2. Nmap

Used to identify open ports and exposed services on the server.

3. OWASP ZAP (Passive Scan)

Used to identify security misconfigurations and vulnerabilities without attacking the system.

4. SecurityHeaders.com

Used to evaluate the presence and effectiveness of security headers.

RISK CLASSIFICATION

Risk levels are classified as follows:

High Risk:

Issues that can directly impact data security or allow attackers to exploit the system easily.

Medium Risk:

Issues that may not immediately compromise the system but increase the likelihood of attacks.

Low Risk:

Minor issues that have limited impact but should still be addressed to improve overall security.

FINDINGS SUMMARY

Issue	**Risk Level**
Website not using HTTPS	High
Missing Security Headers	Medium
Absence of Anti-CSRF Tokens	Medium
Cookie Security Issues	Low
Open Ports Detected	Low
Server Information Disclosure	Low

DETAILED FINDINGS

FINDING 1

Issue: Website not using HTTPS

Risk Level: High

Description:

The application is accessible over HTTP instead of HTTPS, meaning that data transmitted between users and the server is not encrypted.

Impact:

Sensitive information such as login credentials, session data, and personal information may be intercepted by attackers.

Business Impact:

May result in loss of user trust and potential data breaches.

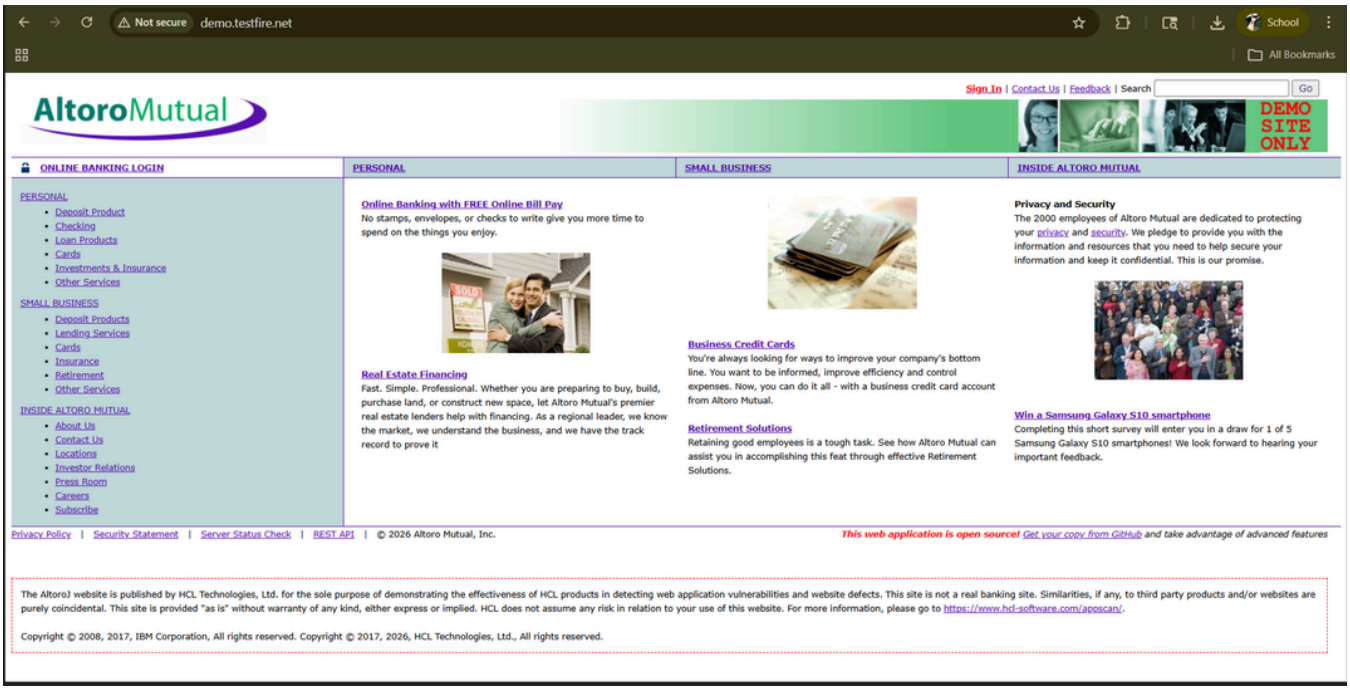
Likelihood:

High, as unencrypted communication is easily exploitable.

Recommendation:

Implement HTTPS using a valid SSL/TLS certificate and enforce secure communication across all pages.

Evidence:



Not secure
demo.testfire.net
AltoroMutual

FINDING 2

Issue: Missing Security Headers

Risk Level: Medium

Description:

The application does not include important security-related headers that help protect against common web attacks.

Impact:

This increases the risk of attacks such as cross-site scripting (XSS) and clickjacking.

Business Impact:

Increases the risk of web-based attacks that can affect user data and damage the organization's reputation.

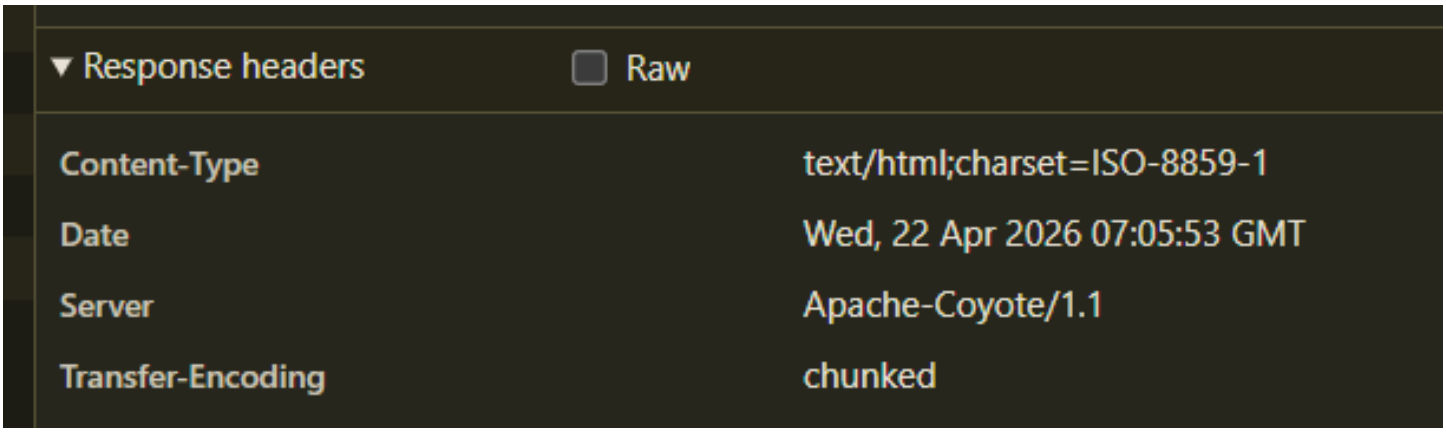
Likelihood:

Medium, as these are common web vulnerabilities.

Recommendation:

Configure appropriate security headers at the server level.

Evidence: Missing security headers observed in response



▼ Response headers Raw

Content-Type	text/html;charset=ISO-8859-1
Date	Wed, 22 Apr 2026 07:05:53 GMT
Server	Apache-Coyote/1.1
Transfer-Encoding	chunked

FINDING 3

Issue: Absence of Anti-CSRF Tokens

Risk Level: Medium

Description:

The application does not include anti-CSRF tokens in forms to verify legitimate user requests.

Impact:

Attackers may perform unauthorized actions on behalf of users without their knowledge.

Business Impact:

Unauthorized actions may be performed on behalf of users, leading to potential misuse of accounts and loss of trust.

Likelihood:

Medium, especially in applications with user interaction.

Recommendation:

Implement anti-CSRF tokens for all sensitive operations.

Evidence:

Absence of Anti-CSRF Tokens

URL: http://demo.testfire.net/login.jsp
Risk: Medium
Confidence: Low
Parameter:
Attack:
Evidence: <form action="doLogin" method="post" name="login" id="login" onsubmit="return (confirminput(login));">
CWE ID: 352
WASC ID: 9
Source: Passive (10202 - Absence of Anti-CSRF Tokens)
Input Vector:

Description:

No Anti-CSRF tokens were found in a HTML submission form.
A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a

FINDING 4

Issue: Cookie without SameSite Attribute

Risk Level: Low

Description:

Session cookies are not configured with the SameSite attribute.

Impact:

Cookies may be sent with cross-site requests, increasing the risk of session misuse.

Business Impact:

Weak cookie security may allow session misuse, impacting user account safety.

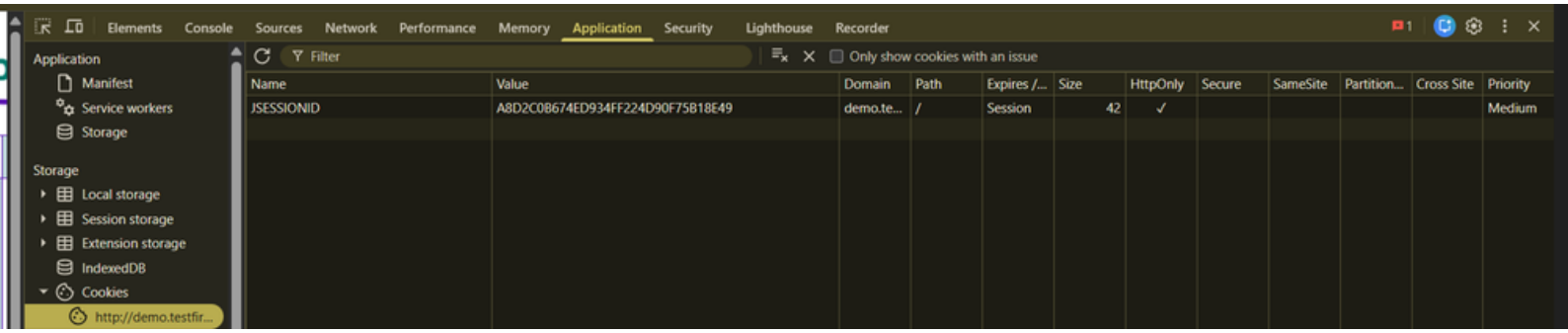
Likelihood:

Low, but still a security concern.

Recommendation:

Set SameSite attribute to Lax or Strict.

Evidence:



FINDING 5

Issue: Open Ports Detected

Risk Level: Low

Description:

The Nmap scan identified open ports including 80 (HTTP), 443 (HTTPS), and 8080.

Impact:

Additional open ports increase the attack surface if not properly secured.

Business Impact:

Unnecessary open ports may expose additional entry points, increasing the risk of unauthorized access.

Likelihood:

Low, but depends on service configuration.

Recommendation:

Review open ports and disable unnecessary services.

Evidence:

```
C:\Users\Admin>nmap -F demo.testfire.net
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-22 12:34 +0530
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.30s latency).
Not shown: 96 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
8080/tcp open   http-proxy
8443/tcp closed https-alt

Nmap done: 1 IP address (1 host up) scanned in 10.23 seconds
```

FINDING 6

Issue: Server Information Disclosure

Risk Level: Low

Description:

The application exposes internal server details through response headers, which should not be publicly visible.

Impact:

Attackers can use this information to identify potential vulnerabilities.

Business Impact:

Exposed server details may help attackers identify vulnerabilities and plan targeted attacks.

Likelihood:

Low, but useful for attackers.

Recommendation:

Disable or limit server information disclosure.

Evidence:

▼ Response headers ☐ Raw

Content-Type	text/html;charset=ISO-8859-1
Date	Wed, 22 Apr 2026 07:05:53 GMT
Server	Apache-Coyote/1.1
Transfer-Encoding	chunked

BUSINESS IMPACT

The identified vulnerabilities may impact the organization in several ways:

- Loss of customer trust due to insecure communication
- Exposure of sensitive user data
- Increased risk of cyber attacks
- Potential compliance and regulatory issues

Addressing these issues will significantly improve security and reliability.

OVERALL RISK ASSESSMENT

Based on the findings, the application has a moderate security risk level.

While no critical vulnerabilities were actively exploited, several medium and low-risk issues exist that could be leveraged by attackers.

Addressing these issues will improve the overall security posture.

LIMITATIONS

This assessment was limited to passive analysis techniques.

No active exploitation or deep penetration testing was performed.

As a result, additional vulnerabilities may exist that were not identified during this assessment.

ASSESSMENT OVERVIEW

The assessment was completed within a limited timeframe using passive analysis techniques on publicly accessible components.

CONCLUSION

The vulnerability assessment identified several security weaknesses in the application.

Although these issues are common, they can significantly impact security if left unaddressed.

It is recommended to prioritize implementing HTTPS, configuring security headers, and improving session security.

Regular security assessments should be conducted to maintain a strong security posture.